

ENTERPRISE SECURITY ASSESSMENT LAB

API Security Evidence Documentation Report

Kiterunner Hidden Endpoint Discovery Evidence

Professional Portfolio Edition - Authorized API Security Lab Evidence

Field	Details
Test Area	Hidden endpoints
Result Type	Endpoint discovery
Evidence Report File	13-kiterunner-hidden-endpoints-discovered-evidence-report.pdf
Testing Phase	API Endpoint Discovery and Inventory Review
Tool / Component	Kiterunner / API Route Enumeration
OWASP / Security Mapping	API9:2023 Improper Inventory Management
Repository Path	02-api-security/reports/evidence/
Prepared For	GitHub recruiter portfolio documentation

This report documents one API Security evidence row as a standalone professional artifact. It includes the embedded screenshot, what it proves, the methodology context, command/workflow, sanitized output style, risk interpretation, remediation guidance, and publication redaction requirements.

1. Embedded Evidence Screenshot

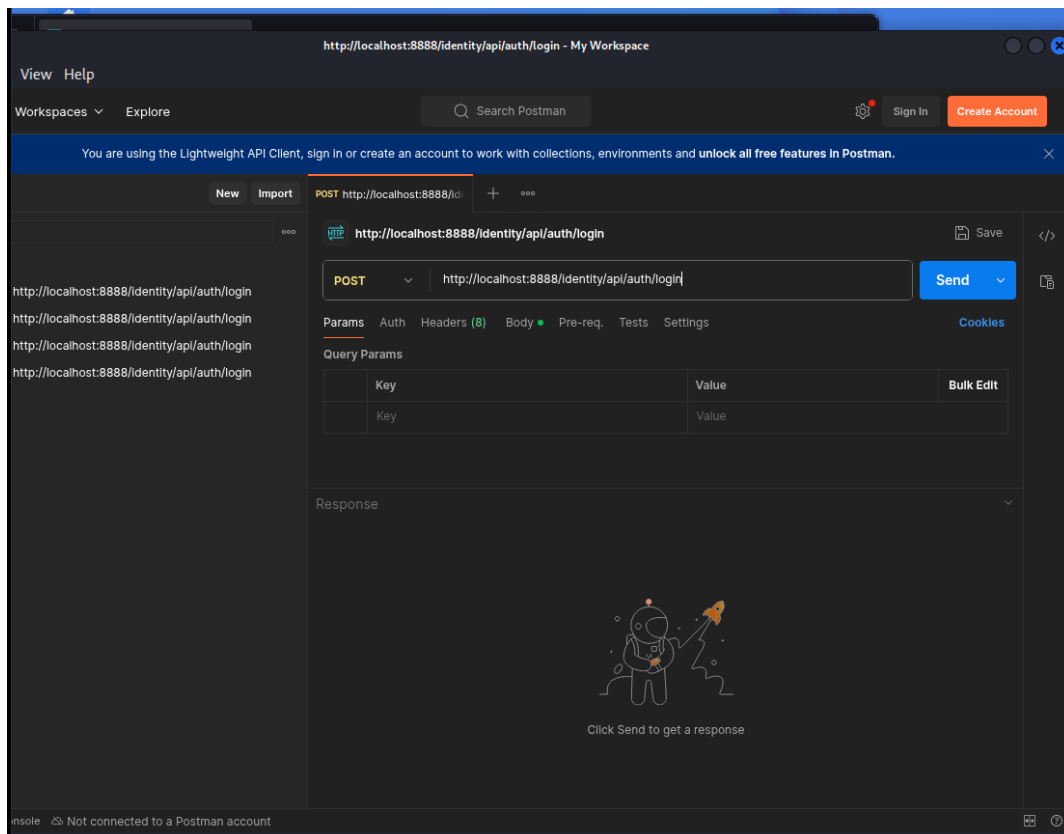


Figure 1 - Embedded screenshot evidence for: Hidden endpoints

What this evidence proves

The evidence shows endpoint discovery activity using an API-aware route discovery tool. This supports API inventory review and attack surface mapping.

Evidence handling note

The screenshot has been prepared for GitHub publication. Sensitive fields such as credentials, tokens, JWTs, cookies, personal data, host values, or other secrets are blurred or represented as redacted values where needed.

2. Assessment Context and Methodology Placement

Area	Value
Testing Phase	API Endpoint Discovery and Inventory Review
Tool / Component	Kiterunner / API Route Enumeration
Assessment Objective	Discover undocumented or hidden API routes that may not be visible through the UI or documented collection.
Result Type	Endpoint discovery
OWASP / Security Mapping	API9:2023 Improper Inventory Management

Why this evidence matters

APIs often have undocumented, legacy, or hidden endpoints. These endpoints still require authentication, authorization, and monitoring even if they are not shown in documentation.

Command / workflow used

```
kr scan http://localhost:8888 -w <routes.kite>  
Review discovered endpoints  
Classify by status code, method, and authentication requirement
```

Sanitized output style

```
Discovered routes: <REDACTED_OR_REVIEWED>  
Status codes: 200 / 401 / 403 / 404 / 405 reviewed  
Authentication requirement: reviewed per endpoint
```

3. Professional Interpretation

This evidence row should be interpreted as: **Endpoint discovery**.

Hidden endpoints can expose legacy functionality, admin routes, debug features, or unauthenticated data paths if not properly controlled.

Assessor notes

Endpoint discovery is a key API-specific reconnaissance activity.

How a recruiter or reviewer should read this evidence

The value of this evidence is not only the screenshot itself. The value is that it demonstrates a structured API security testing process: controlled lab setup, targeted testing, safe interpretation of results, and clear separation between confirmed vulnerabilities and controls that rejected attack attempts.

Finding interpretation

Where the evidence shows vulnerable behaviour, the report should explain the security impact, the affected object or workflow, and the remediation without publishing sensitive raw values.

4. Risk, Impact, and Remediation Guidance

Risk perspective

Hidden endpoints can expose legacy functionality, admin routes, debug features, or unauthenticated data paths if not properly controlled.

Recommended remediation / hardening actions

- Maintain an API inventory.
- Remove deprecated routes.
- Protect every endpoint with authentication and authorization.
- Monitor access to unusual endpoints.
- Review route exposure before release.

Validation guidance after remediation

- Repeat the same test workflow after remediation and compare the response behaviour.
- Confirm that sensitive data is no longer exposed in raw API responses.
- Confirm that unauthorized requests return secure error responses such as 401 or 403 where appropriate.
- Confirm that security controls are enforced server-side, not only in the frontend or client collection.

5. GitHub Publication and Redaction Guidance

Sensitive values to redact before public upload

- Internal endpoint names if sensitive.
- Hostnames.
- Tokens in command output.
- User IDs in URLs.

General API evidence redaction checklist

- Blur JWT access tokens, bearer tokens, OAuth codes, cookies, and authorization headers.
- Blur email addresses, phone numbers, user IDs, vehicle IDs, order IDs, and private object identifiers.
- Do not upload Postman environment files containing live variables or secrets.
- Do not upload raw response exports containing personal data or secret-bearing values.
- Use placeholders such as , , and .

GitHub link format for 02-api-security/README.md

[Hidden endpoints](./reports/evidence/13-kiterunner-hidden-endpoints-discovered-evidence-report.pdf)

Final classification

This PDF is suitable for a public GitHub portfolio only after the embedded screenshot has been reviewed and sensitive values are confirmed blurred or removed.